AutorizaJá

FASE 2 · MACRO ENTREGA 2

Artefato 01

Documento de Arquitetura de Software

Arquitetura proposta, componentes, tecnologias e justificativas das decisões técnicas

Projeto	AutorizaJá: acompanhamento de autorizações em planos de saúde
Aluno	Tony Tomaz
Instituição	UNIFACISA
Entrega	12 de novembro de 2026 · versão 1.0

1. Objetivo e escopo

Este documento descreve a arquitetura do **AutorizaJá**, a partir dos requisitos da Fase 1 (artefatos 02 a 04). Ele apresenta a visão geral do sistema, os módulos, as tecnologias escolhidas, as integrações, as decisões arquiteturais com suas justificativas e os riscos técnicos identificados.

Requisitos que mais influenciam a arquitetura (drivers):

Driver	Origem	Impacto na arquitetura
Dado de saúde é sensível	RNF01–RNF04, LGPD	Criptografia, RBAC, auditoria imutável, URLs assinadas
Integração com o sistema de gestão da operadora	RF16, RNF12	Camada de integração isolada (padrão *adapter*)
Notificações sem travar o usuário	RF06	Processamento assíncrono com fila de mensagens
Prazo em dias úteis e semáforo	RN01–RN03	Regra de domínio centralizada e testável
Equipe de 1 pessoa, MVP em 4 sprints	Restrição do projeto	Arquitetura simples de operar: monólito modular
Público majoritariamente mobile	RNF09	Frontend PWA responsivo

2. Estilo arquitetural: monólito modular em camadas

O backend é um **monólito modular**: uma única aplicação implantável, dividida internamente em módulos de domínio com fronteiras claras (cada módulo tem seus controladores, serviços e repositórios, e só conversa com outro módulo pela interface pública dele). Dentro de cada módulo, o código segue **camadas**: apresentação (API REST) → aplicação (casos de uso) → domínio (regras) → infraestrutura (banco, filas, serviços externos).

Alternativas avaliadas

Alternativa	Vantagens	Desvantagens	Decisão
Microsserviços	Escala e implanta cada serviço separadamente	Complexidade alta de operação, rede, observabilidade e dados distribuídos; desproporcional para 1 desenvolvedor	Rejeitada
Monólito tradicional (sem módulos)	Mais rápido no início	Acoplamento cresce e dificulta evoluir	Rejeitada
Monólito modular	Simples de implantar e testar; módulos podem virar serviços no futuro	Escala como um bloco único	**Escolhida**

Alternativa	Vantagens	Desvantagens	Decisão
Serverless (BaaS)	Pouca infraestrutura	Regras de domínio espalhadas, dependência de fornecedor, integração com rede interna da operadora mais difícil	Rejeitada

3. Visão de contexto

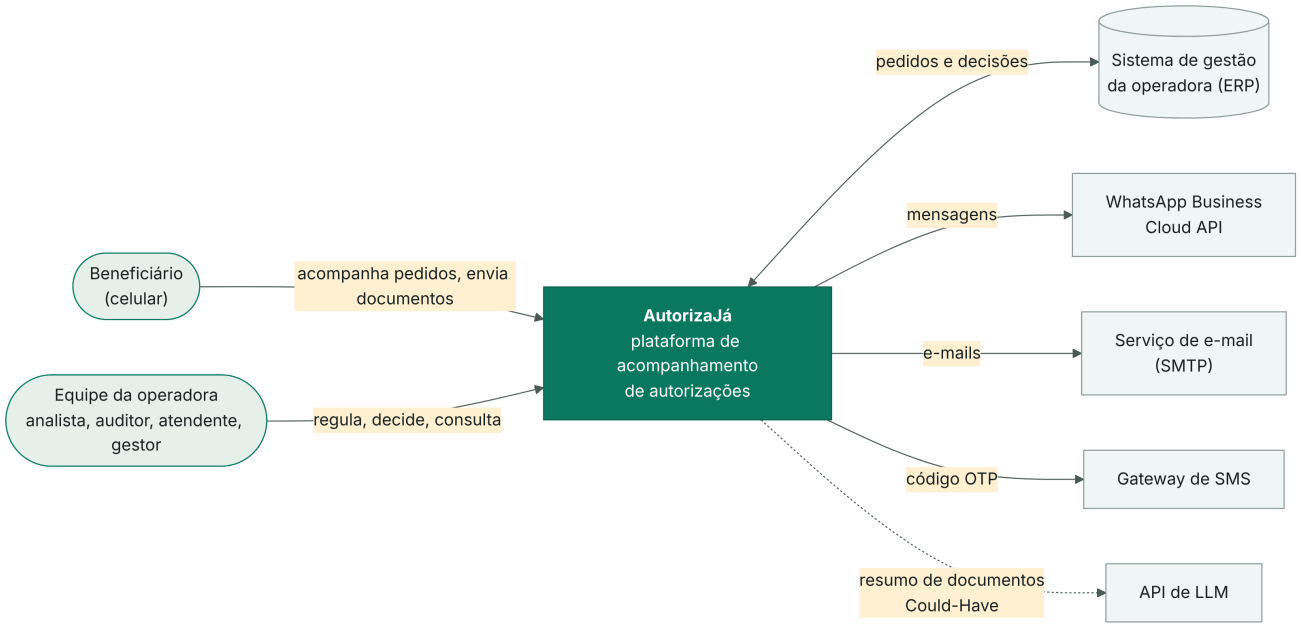


Figura 1: Diagrama de contexto (nível 1 do modelo C4)

4. Visão de containers

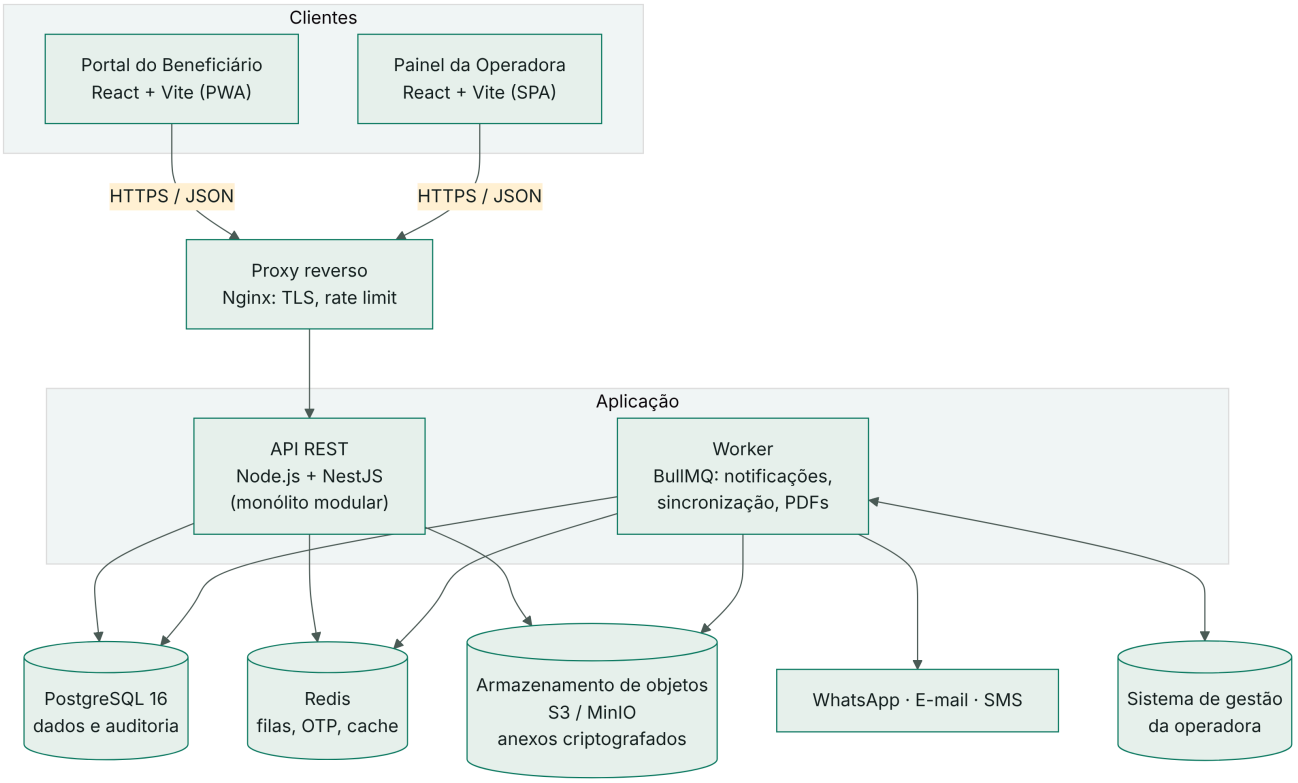


Figura 2: Diagrama de containers (nível 2 do modelo C4)

Container	Responsabilidade	Tecnologia
Portal do Beneficiário	Interface mobile-first instalável; login OTP, pedidos, upload	React 18, Vite, TypeScript, Tailwind CSS, Workbox (PWA)
Painel da Operadora	Fila, detalhe, parecer, dashboard	React 18, Vite, TypeScript, Tailwind CSS, TanStack Table
Proxy reverso	Termina TLS, limita requisições, serve os frontends	Nginx
API REST	Regras de negócio, autenticação, autorização, endpoints	Node.js 20 LTS, NestJS 10, Prisma ORM
Worker	Tarefas assíncronas: envio de notificações, sincronização com ERP, geração de PDF	NestJS + BullMQ
Banco relacional	Dados transacionais e trilha de auditoria	PostgreSQL 16
Redis	Filas de tarefas, códigos OTP com expiração, cache	Redis 7
Armazenamento de objetos	Anexos e PDFs de resposta, criptografados	MinIO (dev) / S3 compatível (produção)

5. Módulos da API (visão de componentes)

Módulo	Responsabilidade	Requisitos
`auth`	Login OTP do beneficiário, login interno, JWT, perfis (RBAC)	RF01, RF09, RN10
`beneficiarios`	Dados do beneficiário, dependentes, preferências de contato	RF07, RN07
`pedidos`	Pedido de autorização, status, linha do tempo, máquina de estados	RF02, RF03, RN12, RN13
`prazos`	Cálculo de data limite em dias úteis, semáforo, feriados	RF04, RF10, RN01–RN03
`documentos`	Upload, validação, armazenamento e URL assinada	RF05, RF12, RN08
`regulacao`	Fila, atribuição, parecer, negativa fundamentada	RF10–RF15, RN05, RN06
`notificacoes`	Montagem e envio de mensagens por canal	RF06, RN09
`integracao`	Conector com o ERP (adaptadores REST e visão de banco)	RF16, RNF12
`relatorios`	Dashboard e exportação	RF17, RF22
`auditoria`	Registro imutável de ações	RF18

Os módulos se comunicam por **chamadas internas** quando a resposta é necessária na hora (ex.: `regulacao` consulta `prazos`) e por **eventos de domínio** quando a ação é consequência (ex.: `pedidos` publica `StatusAlterado`; `notificacoes` e `auditoria` reagem). Isso mantém o baixo acoplamento.

6. Integração com o sistema de gestão

O módulo `integracao` usa o padrão **Adapter**: uma interface única `ConectorERP` com duas implementações, escolhidas por configuração.

- **AdapterRest:** consome a API da operadora (quando existir).
- **AdapterVisaoBanco:** lê uma visão de banco somente leitura disponibilizada pela TI da operadora.

A sincronização roda no Worker a cada 5 minutos (importação incremental por data de alteração) e grava as decisões de volta pelo mesmo adaptador. Falhas entram em fila de nova tentativa com espera exponencial e geram alerta após 3 falhas seguidas.

7. Segurança e privacidade

Tema	Medida
Transporte	HTTPS obrigatório (TLS 1.2+), HSTS
Autenticação	Beneficiário: OTP de 6 dígitos (Redis, 5 min). Interno: e-mail + senha Argon2id. Tokens JWT de acesso (15 min) + refresh token rotativo em cookie *httpOnly*
Autorização	RBAC por perfil + verificação de propriedade do recurso (beneficiário só acessa seus pedidos)

Tema	Medida
Anexos	Criptografia no servidor (SSE), acesso por URL assinada de 5 min, verificação de tipo real do arquivo
Dados sensíveis	CPF e telefone mascarados nas telas internas quando não necessários; logs sem dados pessoais
Auditoria	Tabela somente inserção (sem UPDATE/DELETE para o usuário da aplicação)
Ataques comuns	Validação de entrada (class-validator), ORM com consultas parametrizadas, rate limit no login, CORS restrito, cabeçalhos Helmet
LGPD	Registro de base legal, política de retenção, relatório de dados tratados para o titular

8. Implantação

- **Desenvolvimento:** Docker Compose com API, Worker, PostgreSQL, Redis, MinIO e Mailpit (e-mail falso para testes).
- **Produção (proposta):** contêineres em uma VM ou serviço gerenciado de contêineres, banco PostgreSQL gerenciado com backup diário, armazenamento S3 compatível. Implantação automática pela pipeline do GitHub Actions após aprovação do PR na branch `main`.

9. Registro de decisões arquiteturais (ADR)

ADR	Decisão	Justificativa
ADR-01	Monólito modular	Menor custo operacional para equipe pequena; módulos preparam extração futura
ADR-02	TypeScript no front e no back	Uma linguagem só, tipos compartilhados, menos erros de contrato
ADR-03	NestJS em vez de Express puro	Estrutura modular nativa, injeção de dependência e testes facilitados
ADR-04	PostgreSQL	Relacional, transacional, maduro, bom suporte a JSON e auditoria
ADR-05	Fila (BullMQ/Redis) para notificações e integração	Usuário não espera envio externo; permite nova tentativa automática
ADR-06	PWA em vez de app nativo	Atende mobile com um único código e sem publicação em lojas
ADR-07	Prazos parametrizáveis em tabela	Normas mudam; alterar parâmetro não exige nova versão do sistema
ADR-08	IA apenas para resumo, nunca para decisão	Responsabilidade clínica e risco regulatório (ver Plano de IA)

10. Riscos e limitações técnicas

Risco / limitação	Prob.	Impacto	Mitigação
ERP da operadora sem API ou com acesso restrito	Alta	Alto	Adaptador por visão de banco; dados de simulação para o MVP acadêmico
Custos e aprovação de templates do WhatsApp	Média	Médio	E-mail como canal padrão; WhatsApp ativado por configuração
Vazamento de dados sensíveis	Baixa	Muito alto	Medidas da seção 7, testes de segurança (OWASP ZAP) antes da release
Calendário de feriados incorreto afeta prazos	Média	Alto	Cadastro de feriados nacionais/municipais com revisão anual e testes do cálculo
Monólito escala como bloco único	Baixa	Médio	API sem estado (*stateless*), permite várias instâncias atrás do proxy
Sincronização periódica gera atraso de até 5 min	Alta	Baixo	Aceito no MVP; suporte a webhook previsto quando o ERP permitir
Projeto desenvolvido por uma pessoa	Alta	Médio	Escopo limitado ao MVP, automação de testes e CI